BÁO CÁO SỰ CỐ XÂM NHẬP MÁY CHỦ STAGING `bom-stg-all2`

- **Phiên bản:** 24/10/2026, khoảng 18:30 (+07)
- **Người thực hiện xử lý trên máy:** ALO. Claude chỉ phân tích output do ALO dán vào cuộc trò chuyện và không truy cập máy. Mọi mục "ĐÃ XÁC MINH" trong báo cáo đều dựa trên output đó.
- **Nguồn dữ liệu:** toàn bộ project chat từ 23/10 đến 24/10; thread "Hoàn tất runbook bom-stg-all2"; runbook `/mnt/project-files/ir/runbook-23-10.md`; bộ nhớ dự án. Hai thread "Điều tra webshell" và "Khoanh vùng và dọn" bị bộ lọc an toàn chặn vì có chứa nguyên văn tài liệu của kẻ tấn công. Báo cáo chỉ dùng phần tóm tắt IOC của hai thread này đã được lưu trong bộ nhớ dự án (gọi tắt là [MEM]), nên các mục lấy từ đó được đánh dấu riêng.
- **Quy ước giờ:** dùng giờ Việt Nam (+07) nếu không ghi khác. Log nginx cũ (`*.access.log.2.gz` trở đi) ghi theo UTC (+0000), log `.1` và log hiện tại ghi theo +07. Kết quả `stat` ghi theo +07.
- **Trạng thái:** `✅ ĐÃ XÁC MINH` · `🟡 ĐÃ THỰC HIỆN NHƯNG CHƯA XÁC MINH` · `❌ CHƯA XỬ LÝ` · `🔍 CẦN ĐIỀU TRA THÊM` · `— CHƯA CÓ DỮ LIỆU`
- **Loại biện pháp:** `TẠM THỜI` · `VĨNH VIỄN` · `CHƯA XÁC ĐỊNH`
- Báo cáo **không** chứa mật khẩu, token, private key, cookie, khoá của webshell, nội dung tài liệu hay script của kẻ tấn công.

---

1. TỔNG QUAN SỰ CỐ

Hạng mục	Nội dung
Thời điểm xâm nhập	14/10/2026 00:18:43 (+07), tức 13/10 17:18:43 UTC: kẻ tấn công lấy được phiên autolms ở site ftu. ✅
Thời điểm phát hiện	23/10/2026 (ngày bắt đầu điều tra). Giờ phát hiện chính xác và người phát hiện: — CHƯA CÓ DỮ LIỆU
Thời gian kẻ tấn công lưu trú	Khoảng 10 ngày, từ 14/10 00:18 đến lượt gọi webshell cuối cùng ngày 23/10 (16:17 theo log ftu.access.log.1; ALO ghi nhận traffic webshell tới khoảng 20:18). ✅/🔍
Máy bị ảnh hưởng trực tiếp	`bom-stg-all2` (IP nội bộ 10.0.10.128), Ubuntu 24.04, nginx 1.24.0, PHP-FPM 7.4 và 8.2, đứng sau reverse proxy công ty `103.252.72.136`
Site bị cài mã độc	9 site: bav, haui, nau, qbu, tmu, ftu (autolms), dhv26, inu26, tvu26 (thư mục `public/`). ✅
Site cùng máy, không thấy mã độc	dnu, ecouni, gp (gp26), staff-lms.ftu.edu.vn, 16 vhost `api-*`. Không thấy loader, nhưng vẫn chạy chung user `www-data` nên không loại trừ việc bị đọc hoặc sửa.
Dấu hiệu ban đầu	Có file PHP lạ `plg_cache_*.php` trong web root của 9 site; có traffic gọi webshell từ IP ngoài; có bộ công cụ tấn công trong `/tmp` và `/var/tmp/.syslibs`; có 108 private key trong `.glyph`. ✅
Phạm vi đã xác minh	Kẻ tấn công thực thi mã dưới quyền `www-data` trên `bom-stg-all2`. Họ đã đọc được dump `/data/lmshaui_20261013.sql`, `.git/config` (có token remote) và `/opt/*/.env`. Họ dùng key lấy được để đăng nhập SSH vào `root@103.252.72.221`, `root@103.252.73.52` và `dev01@103.252.73.238` (có sudo), và thử MySQL `dtw_26@27.71.21.34`, `stw3-be@27.71.21.176:63306`. Nguồn: [MEM] kết quả 10e.
Phạm vi còn nghi vấn	GitLab và biến CI/CD (108 key đặt tên theo kiểu biến CI). Node production DNU và NAU (có key trong `.glyph`). Mọi production chạy chung code autolms. Airflow (`af_win.ck`). Reverse proxy `103.252.72.136` và `oaa-apigw-stg` (`103.252.73.180`), vì cả hai nằm trong dải IP bị dò SSH. Các dải 103.252.72–74.x, 10.0.2.x, 10.0.3.233, 10.0.10.x, 192.168.0.x bị dò SSH. 🔍
Mức độ nghiêm trọng	**NGHIÊM TRỌNG (Critical).** Lý do: thực thi mã từ xa trên máy chạy 11+ site; private key và token bị lấy; đã di chuyển ngang sang ít nhất 3 máy với quyền root hoặc sudo; dữ liệu cá nhân (dump LMS HAUI) đã bị đọc.

Nguyên nhân gốc	✅ Lỗ trong ứng dụng autolms. `login/set_login` tin cookie `autolms_data` chỉ được base64 + JSON, không ký (dòng `decodeId` bị comment), nên ai cũng tự tạo được phiên với vai trò manager. Thêm vào đó, `autocourse/osp/import` nhận mọi loại file (`allowed_types="*"`) và lưu vào `autolms/upload/` , thư mục nằm trong web root và cho phép chạy PHP. Chi tiết ở mục 8.
Tình trạng hiện tại	**KIỂM SOÁT MỘT PHẦN.** Trên `bom-stg-all2` : đường vào đã bị chặn tạm ở nginx, mã độc đã bị gỡ, quyền ghi code đã bị khoá, egress của `www-data` đã bị chặn, và chưa thấy mã độc quay lại. Tuy vậy: **chưa xoay vòng bất kỳ bí mật nào**, 3 máy bị lan sang chưa được xử lý, GitLab và production chưa được kiểm tra, code chưa được vá, và máy chưa được dựng lại.

2. DIỄN BIẾN SỰ CỐ

2.1 Timeline

Thời điểm (+07)	Sự kiện	Bằng chứng	Mức chắc chắn
09/10–12/10	Code các site được triển khai. 12/10 17:09–17:13 có đợt chown sang `www-data` khoảng 205.000 file. Từ đây toàn bộ code thuộc `www-data` .	ctime theo đợt (10d2) [MEM]	✅
13/10 23:32–23:42 (16:32–16:42 UTC)	`61.124.1.29` (IP của sự cố trước) dùng `curl/8.14.1` dò `set_login` và `osp/import` . Mọi phản hồi đều 38 byte, tức là bị từ chối.	Log nginx ALO dán (mục 5c)	✅
14/10 00:13:45 (17:13 UTC)	`49.51.33.159` gọi `GET /local/hd72/index.php` ở bav và nhận 303. Chưa rõ có liên quan hay không.	Log 5c	🔍
14/10 00:18:43	**ftu:** `set_login` trả 383 byte và `osp/import` trả 13711 byte. Kẻ tấn công **đã có phiên**. Ở bav, haui, nau, qbu, tmu, mọi lần thử đều trả 38 byte (thất bại).	`12_3a2.txt`	✅
14/10 00:19:00	`POST /autolms/index.php/autocourse/osp/import` ở ftu, ngay sau đó `GET /autolms/upload/ft9.php` trả 200.	`ftu.access.log.10.gz`	✅
14/10 00:19:00–00:20:51	64 request tới `ft9.php` (UA `curl/8.0`), kích thước phản hồi thay đổi theo từng lần, tức là đang chạy lệnh.	`ftu.access.log.10.gz:64`	✅
14/10 00:20:09–00:20:51	Ghi lần lượt 9 cặp **loader** `plg_cache_<id>.php` + **payload** vào 9 site trong vòng 42 giây (script tự động). mtime bị lùi giả về 09–12/10 (mtime < birth).	`webshell_times.txt` (birth/mtime/ctime)	✅
14/10 00:20:51	`ft9.php` bị xoá (mtime thư mục `ftu/autolms/upload` đúng giây đó).	7b	✅ (suy từ mtime)
14/10 00:30:21 (17:30 UTC)	`61.124.1.29` gọi `set_login` trên vhost mặc định (`access.log.11.gz`), nhận 404.	`12_3a2.txt`	✅
14/10 08:53:45	`www-data` tạo 28 file plugin `mod/onschoolliveclass` ở ftu, cùng một giây.	10d3 [MEM]	🔍 nghi cài qua Moodle admin, chưa xác nhận
14/10 15:46	Thư mục `/var/www/haui/autolms/application/cache/.glyph` được tạo, chứa 108 private key, owner `www-data` .	`12_1.txt`	✅
14/10 → 23/10	`180.93.160.36` (= `d.zzkefa.com` , C2) điều khiển chủ yếu qua webshell ftu:	10e [MEM]	✅ theo [MEM]; output gốc không được

	đọc dump HAUI, `.git/config`, `/opt/*/.env`; dò SSH nhiều dải; đăng nhập 3 máy; thử 2 MySQL.		đọc lại vì thread bị chặn
15/10 01:22	Tạo `/var/tmp/.syslibs/` (tài liệu triển khai cửa sau, thư viện `.so`, script Python), owner `www-data`.	`12_1.txt`	✅
16/10 00:17:53 (17:17 UTC)	`158.247.235.77` gọi `set_login` và `import` ở tmu, nhận 500 (1470 byte).	`12_3a2.txt`	✅
20/10 16:39, 21/10 14:35–14:37, 22/10 09:45	`config.php` của ecouni, ftu (cùng 2 file config autolms và lipe) và haui bị `www-data` sửa. Thời điểm này nằm trong khoảng kẻ tấn công đang có quyền `www-data`.	stat ctime (24/10 15:37)	🔍 nghi dev sửa vì trong giờ hành chính, **chưa xác nhận**
19/10, 20/10	`amd/build/*.min.js` ở tvu26, inu26 bị `www-data` ghi lại (JS chạy trên trình duyệt người dùng).	find (24/10 15:37)	🔍 nghi dev build, chưa xác nhận
23/10 (trong ngày)	Webshell vẫn bị gọi từ `180.93.160.36`, `103.76.182.40`, và 102 lượt ghi IP `103.252.72.136` (proxy công ty; IP thật phía sau chưa rõ).	Tóm tắt của ALO ngày 23/10	✅ / 🔍 nguồn thật của 102 lượt
23/10 09:53, 11:01, 14:25	Tài khoản `deploy` được tạo lại; loader dhv26 bị chown sang `deploy`; `authorized_keys` của deploy đổi.	10b [MEM]	Runbook ghi "giải thích được", chi tiết xác nhận — CHƯA CÓ DỮ LIỆU
23/10 16:08–16:17	`180.93.160.36` gửi 60 request `POST /autolms/plg_cache_uxi8sv56.php` ở ftu, đều trả 200. Đây là lượt cuối thấy trong log.	`ftu.access.log.1`	✅
23/10 17:18:59	`haui/local/core/report/f350/index.php` bị `www-data` sửa, root commit `d6909c33a` lúc 17:21:58.	stat + git	✅ ALO xác nhận hợp lệ
23/10 17:25, 20:50	ALO xoá nội dung `/root/.ssh` và (theo ALO) thư mục `.glyph`.	Lời ALO	🟡 xem mục 3
23/10 ~22:11	Bắt đầu thu bằng chứng (`IR=/root/ir/20261023-2211`); chặn nginx (`ir-block.conf`); kill tiến trình lạ của `www-data`. Theo runbook trước của ALO.	Lời ALO; output 24/10	✅ phần chặn nginx; 🟡 phần kill
23/10 22:35	Giải mã 2 payload woff2 (bav, tvu26) ra `$IR/payload/`. Trước thời điểm đóng gói, ALO đã xoá 9 loader và 2 woff2.	7a, 10d3 [MEM]	✅
24/10 01:26	Chặn C2 bằng iptables và `/etc/hosts`. 5 gói `IR_C2_OUT` lúc 01:26:25–01:26:29 do chính lệnh curl kiểm tra tạo ra.	10a, journal	✅
24/10 02:28–02:45	12.1 (không thấy dấu hiệu root), 12.2 (lưu `sess_ahmxcasd.log`), 12.3 (xác định lỗ gốc). Chặn `set_login` (ir-block.conf mtime 02:46).	output thread	✅
24/10 13:26	Chạy khối rà soát: 11/13 vhost trả 403, chưa thấy mã độc quay lại.	`verify_*.txt`	✅
24/10 15:16	Gộp danh sách deny 12 IP vào `ir-block.conf` (trước đó `ir-deny.conf` **chưa từng tồn tại**).	`ls conf.d` = trống; `nginx -t` ok	✅
24/10 15:21–15:31	Thêm `disable_functions` vào mọi pool FPM; xoá công cụ trong /tmp và `.syslibs`; bật noexec; tạo cron `ir-watch`; cài `iptables-persistent`; chặn egress `www-data`.	output 08:23Z, 08:31Z	✅ / 🟡 (mục 6)
24/10 15:38–15:55	Tìm đủ payload của 9/9 site. Lưu 6 payload, đổi `chmod 000`, xoá. Thêm rule nginx chặn mẫu tên payload; kiểm tra trả 403.	output 08:38Z–08:55Z	✅

24/10 15:38	Chuyển `.mcp.json`, `CLAUDE.md`, `.cursor/`, docx/xlsx, `FTUHL/` khỏi web root ftu sang `/root/ftu-moved`.	output 08:38Z	✅
24/10 16:03–16:45	Đổi owner code 11 site sang `deploy:www-data` 755/644. Còn 0 file PHP thuộc `www-data`. Kiểm tra nau: site chạy, `www-data` không sửa được `index.php`.	output 09:03Z–09:45Z	✅

2.2 Hành vi kẻ tấn công (tóm tắt theo chuỗi tấn công)

Giai đoạn	Hành vi	Bằng chứng
Trinh sát	Dò `set_login` / `osp/import` trên nhiều site bằng curl	log 13/10 16:32–17:18 UTC
Truy cập ban đầu	Giả cookie phiên autolms ở ftu → upload `ft9.php` qua `osp/import` → chạy PHP	log ftu + mã `set_login` / `osp.php` (12.3b)
Thực thi	`ft9.php` (đã xoá) chạy lệnh dưới `www-data`	64 POST, kích thước phản hồi thay đổi
Duy trì	9 cặp loader + payload ngụy trang (header plugin giả, tên file font/cache/img/sess/idx), mtime giả	`webshell_times.txt`, payload 9/9
Né tránh	Lùi timestamp; tách mã độc thành loader vô hại bề ngoài + payload mã hoá; lệnh gửi trong body POST nên nginx không ghi; xoá `ft9.php`; công cụ để vượt `disable_functions` (`bypass_df*.so`)	stat, `.syslibs`
Thu thập thông tin xác thực	108 private key gom vào `.glyph`; đọc `.git/config`, `/opt/*/.env`, `config.php`	`12_1.txt`, 10e [MEM]
Dò quét và tấn công mật khẩu	Thử mật khẩu Airflow (`af*.py`, `af*.ck`, `af_win.ck`); spray SSH key (`ks.sh`, `ksres.txt`)	danh sách /tmp (24/10 15:04)
Di chuyển ngang	SSH vào 3 máy; thử MySQL 2 server	10e [MEM]
Lấy dữ liệu	Đọc `/data/lmshaui_20261013.sql`	10e [MEM]
C2	`d.zzkefa.com` → `180.93.160.36` (HTTP 80 `/data/`, HTTPS 31443 cert tự ký)	8h/10a [MEM]

3. MÃ ĐỘC VÀ DẤU HIỆU TẤN CÔNG

3.1 Mã độc đã xác nhận

#	Tên	Đường dẫn	Hash	Chức năng	Bằng chứng	Xử lý	Thời điểm	Xác minh	Nguy cơ còn lại
M1	`ft9.php` (webshell ban đầu)	`/var/www/ftu/autolms/upload/ft9.php`	— CHƯA CÓ (file không g	Chạy lệnh, cài 9 cặp loader	64 hit trong `ftu.access.log.10.gz`	Kẻ tấn công tự xoá	14/10 00:20:51	✅ `find / -iname 'ft9*'` rỗng	Thấp. Không có mẫu để phân tích.

			còn)						
M2	Loader `plg_cache_3a3a2db4.php` (966 B)	`/var/www/bav/autolms/`	—	Loader ngụy trang header plugin Joomla. Che tên hàm (rot13), đọc payload, giải mã ra file tạm trong /tmp, include rồi xoá	Mã ALO dán ngày 23/10	ALO xoá	23/10, trước 22:35	✅ không còn trên đĩa (10d2)	Không còn bản gốc; chỉ còn `webshell_times.txt`
M3–M10	8 loader còn lại: `haui/autolms/plg_cache_1psw086j.php` (999 B), `nau/autolms/plg_cache_68kbwbyq.php` (999), `qbu/autolms/plg_cache_u36ebd4d.php` (997), `tmu/autolms/plg_cache_cp6muip7.php` (973), `dhv26/public/plg_cache_d7be5l2a.php` (1019, owner `deploy` 640), `inu26/public/plg_cache_ahmxcasd.php` (1007), `tvu26/public/plg_cache_fw5pwbwn.php` (989), `ftu/autolms/plg_cache_uxi8sv56.php` (999)	như cột Tên, gốc `/var/www/`	—	Như M2	`webshell_times.txt` (birth 14/10 00:20:10–00:20:50)	ALO xoá	23/10	✅	Như M2
M11	Payload webshell `font_3a3a2db4.woff2`	`/var/www/bav/autolms/`	md5 bản giải mã `870` `58e` `b6b` `713` `661` `0f0` `0cf`	Webshell có xác thực (khoá đổi theo ngày và tên miền): liệt kê, đọc, ghi, xoá file; sửa timestamp; chạy lệnh; lấy thông tin máy	Bản giải mã trong `$IR/payload/`	ALO xoá; lưu `woff2.tgz` + `.decoded.txt`	23/10	✅	—

			`57c` `7cb` `a04` `11`						
M12	Payload `font_fw5pwbwn.woff2`	`/var/www/tvu26/public/`	md5 bản giải mã `522` `dcc` `845` `586` `399` `5b4` `3f3` `4f0` `c6d` `8aa` `b5`	Cùng họ M11, nội dung khác (chưa so diff)	như trên	như trên	23/10	✅	—
M13	Payload `sess_ahmxcasd.log` (2566 B)	`/var/www/inu26/public/`	`fea` `371` `613` `014` `d30` `ada` `f01` `c89` `8bd` `5c2` `732` `efb` `b2d` `6d2` `7ac` `a8f` `7b2` `44c` `14b` `d6a` `dba` `c`	Payload của loader inu26	`12_1.txt`, birth 14/10 00:20:40	Lưu `sess_payload.tgz`, `chmod 000`	24/10 02:35	🟡 **Chưa xác nhận đã xoá** (vẫn có trong lần `find` lúc 15:43). Ngoài ra, nếu file còn thì hàm `fix inu26` (16:20) đã đổi quyền nó lại thành **644, owner deploy**.	Thấp: không còn loader, và rule nginx `sess_*.log` trả 403. Cần xoá.
M14	`cache_uxi8sv56.bin`	`/var/www/ftu/autolms/`	`31d` `bbf` `cf4` `7f1`	Payload loader ftu	2566 B, birth 14/10 00:20:50	Lưu, `chmod 000`, `rm`	24/10 15:40–15:50	✅ (rm chạy không lỗi; `img_abcd1` `234.jpg`	—

			`87f` `ac7` `d8e` `04a` `de2` `5a9` `ebe` `c84` `2ff` `e56` `f7a` `8e8` `989` `9cb` `3d8` `345` `1b4` `6`					test 403)
M15	`cache_1psw086j.bin`	`/var/www/haui/autolms/`	`16a` `7be` `9e1` `8ec` `ec5` `534` `c6b` `a84` `077` `336` `035` `c30` `b3c` `f02` `044` `1c2` `246` `6b3` `ea4` `65f` `353` `c`	Payload loader haui	2566 B	như M14	như M14	✅	—
M16	`img_cp6muip7.jpg`	`/var/www/tmu/autolms/`	`01d` `ae5` `b70` `b9e` `d00` `58e`	Payload loader tmu	2566 B	như M14	như M14	✅	—

			`107` `4db` `648` `6fb` `27f` `3c8` `30c` `c5f` `321` `d24` `e22` `bdd` `c99` `a30` `cb6` `0`						
M17	`img_68kbwbyq.jpg`	`/var/www/nau/autolms/`	`d9a` `d6a` `4bc` `e0d` `c29` `60f` `cf8` `3f8` `745` `947` `585` `815` `b01` `dfd` `c76` `635` `6f2` `afe` `9a7` `70a` `c8b` `6`	Payload loader nau	2566 B, birth 14/10 00:20:34	như M14	như M14	✅	—
M18	`idx_u36ebd4d.dat`	`/var/www/qbu/autolms/`	`b84` `356` `610` `9f1` `314` `46a` `bf6` `287`	Payload loader qbu	2566 B, birth 14/10 00:20:35	như M14	như M14	✅	—

			`583aa4035247464` `66b1c9e3c21d8d3` `84453c5384`						
M19	`img_d7be5l2a.jpg`	`/var/www/dhv26/public/`	`facfea82f4eebc3` `bace7a7e7bbe06d` `a86aeb0c13b124b` `c61d7902840328c` `5eb3`	Payload loader dhv26	2566 B, owner `deploy`, birth 14/10 00:20:38	như M14	như M14	✅	—
M20	Bộ `.syslibs`: `bdoor-deploy-v7.md` (`ef47994c…4855`), `bdoor-deploy-v8.md` (`07a7925d…7fdd`), `bypass_df.so` (`d07f4e2b…a6d`), `bypass_df3.so` (`1fc16be2…80b6`), `v7_curl_transport.`	`/var/tmp/.syslibs/`	sha256 đầy đủ trong `12_1.txt`	Tài liệu triển khai cửa sau; thư viện nghi dùng để vượt `disable_functions` (LD_PRELOAD); script truyền tải và quản lý file	`12_1.txt`, owner `www-data`, birth 15/10 01:22	Đã lưu trong `tmp.tgz`. Các file chính biến mất trước 13:09 24/10 (**không rõ ai xoá**); `__pycache__` còn lại được lưu `syslibs_left.tgz` rồi `rm -rf`	24/10 15:22	✅ `ls` trống	Không rõ đã chạy trên máy nào khác

	`py` (`053351c0…dee0`), `v7_stealth_fm.py` (`dd99ea45…2485`), `v8_stealth.py` (`62daa337…8bd5`)								
M21	Công cụ Airflow: `af.py`, `af2.py`… `af12.py`, `af.html`, `dags.json`, `af.ck`, `af_win.ck` và 7 file `.ck` khác (tên chứa cặp tài khoản/mật khẩu bị thử)	`/tmp/`	—	Thử mật khẩu Airflow; `af_win.ck` nghi là có một cặp đăng nhập thành công	`ls /tmp` (24/10 15:04)	Xoá (đã lưu trong `tmp.tgz`)	24/10 15:22	✅ `ls`	grep` trống
M22	Công cụ SSH spray: `ks.sh`, `ks_2666876.txt`, `ks_2672157.txt`, `ksres.txt`	`/tmp/`	—	Thử SSH bằng key lấy được trên nhiều dải IP	như trên	như trên	24/10 15:22	✅	Kết quả `ksres.txt` chưa được phân tích ở mức từng host (10e chỉ nêu 3 máy)
M23	`.glyph` (108 private key)	`/var/www/haui/autolms/application/cache/.glyph`	Có bản lưu `glyph.tgz` (chứa private key)	Kho key để spray SSH	`12_1.txt`	ALO cho biết đã xoá (23/10 20:50 hoặc sau 02:28 24/10)	—	🟡 **Không có output xác nhận.** Lần `12.1` lúc 02:28 vẫn thấy 108 file, mâu thuẫn với mốc 20:50.	**Key vẫn còn hiệu lực trên các server đích** (mục 4)
M24	`gkiz045m`, `plg_cache_ftu.php`	—	—	Webshell khác (theo bản tóm tắt của ALO ngày 23/10)	Chỉ có trong lời kể	Đã bị xoá trước khi điều tra	—	—	Không có mẫu

3.2 File đáng ngờ, chưa kết luận hoặc đã giải thích

File / dấu hiệu	Đường dẫn	Kết luận hiện tại	Trạng thái
`config.php` (www-data sửa 20/10 16:39)	`/var/www/ecouni/config.php`	Nghi dev sửa. Không có git để đối chiếu (file bị ignore).	🔍 chờ dev xác nhận
`config.php` + `autolms/application/config/config.php` + `lipe/system/cms/config/`	`/var/www/ftu/`	Như trên	🔍

`config.php` (21/10 14:35–14:37)			
`config.php` (22/10 09:45)	`/var/www/haui/config.php`	Như trên	🔍
13 file `amd/build/*.min.js(.map)` + `npm-shrinkwrap.json` (19–20/10, www-data)	`inu26/`, `tvu26/public/local/autocourse/`	Nghi dev build bằng grunt. Đây là JS chạy trên trình duyệt người dùng, nên nếu bị chèn sẽ ảnh hưởng người dùng.	🔍 chưa so với bản build sạch
Plugin `mod/onschoolliveclass` (28 file, 14/10 08:53:45, www-data)	`/var/www/ftu/`	Thời điểm nằm trong khoảng kẻ tấn công có quyền. Có `base64_decode` (đã đánh giá là giải mã token, bình thường).	🔍 chưa có xác nhận ai cài
Đợt sửa của root 23/10 15:45 (≈30 file autolms, local/core, dev/import_mtb)	`/var/www/bav/`	Nhiều khả năng là deploy	🔍 chờ xác nhận
`lib/moodlelib.php` trạng thái M	`dnu`, `bav`	Bản vá null-check của dev	✅ sạch (10d) [MEM]
`theme/edumy/settings.php` khớp grep	8 site	Không có rot13/XOR, vô hại	✅ (8c) [MEM]
`local/core/report/f350/index.php`	`haui`	Khớp commit `d6909c33a`, không có hàm webshell	✅ ALO xác nhận hợp lệ
`autolms/application/modules/autocourse/controllers/test.php` (rỗng)	`nau`	Đề nghị xoá	❌ chưa xác nhận đã xoá
`setting_lipe.php` import CSV qua `$_FILES`	`haui`, `tmu`	Có thể là lỗ upload thứ hai	🔍 chưa review
46 file autolms/lipe lệch giữa các site	nhiều site	Tuỳ biến nghiệp vụ, birth 12/10 (trước tấn công)	✅ (10d4) [MEM]
Các file Moodle cỡ 2566 B (`predict_models.php`, `MetaInf.php`…)	nhiều site	Nhiều khả năng là file gốc trùng cỡ. Lệnh `git status` kiểm tra **chưa được dán kết quả**.	🟡
Tài liệu nội bộ trong web root ftu (`.mcp.json`, `CLAUDE.md`, `.cursor/`, docx/xlsx, `FTUHL/`, `TAO_COURSE.md`)	đã chuyển `/root/ftu-moved`	Grep không thấy tên biến KEY/TOKEN/SECRET/PASS trong `.mcp.json`; log không có lượt tải qua HTTP. Tuy vậy, kẻ tấn công có shell `www-data` ở ftu nên có thể đã đọc trực tiếp.	🟡
`49.51.33.159` gọi `/local/hd72/index.php` (bav, 14/10 00:13)	log	Chưa phân tích	🔍
102 lượt gọi webshell ghi IP `103.252.72.136` (23/10)	log	Do vhost chưa có realip lúc đó; IP thật chưa rõ	🔍

3.3 Không phát hiện (không đồng nghĩa với sạch)

- Không thấy loader chèn vào file PHP có sẵn: đã kiểm tra bằng git status, grep chữ ký (`LC_ALL=C -a`) và so chéo md5 giữa 8 site (10d–10d4) [MEM]. Đến 24/10 15:04, grep chữ ký rot13/XOR trên `/var/www` vẫn rỗng.
- Không thấy persistence mức root: `ld.so.preload` trống, `dpkg --verify` sạch, PAM và `.bashrc` giải thích được (10b/10g) [MEM].
- Không thấy tiến trình lạ của `www-data` (13:26 24/10; chỉ có nginx worker và php-fpm).
- Không thấy cron, systemd, `authorized_keys` mới kể từ 23/10 20:00 (verify 13:26 24/10).

4. TÀI KHOẢN VÀ THÔNG TIN XÁC THỰC

Nguyên tắc: xoá file trên máy **không** làm thông tin xác thực hết hiệu lực. Bí mật chỉ coi là xử lý xong khi đã thu hồi hoặc đổi tại hệ thống cấp phát (GitLab, server đích, DB, Airflow…). Đến thời điểm báo cáo, **chưa có bí mật nào được xác nhận là đã xoay vòng**.

#	Loại thông tin	Vị trí trên máy	Mức lộ	Đã làm trên máy	Đã thu hồi/ đổi tại nguồn	Trạng thái
C1	108 private SSH key (tên kiểu biến CI GitLab, có key node PRO DNU/NAU, deploy key GitLab)	`.glyph` (haui)	**Chắc chắn lộ.** Kẻ tấn công đã gom và dùng chúng.	ALO cho biết đã xoá `.glyph` (🟡)	— CHƯA CÓ DỮ LIỆU	❌
C2	Key dùng để vào `root@103.252.72.221`, `root@103.252.73.52`, `dev01@103.252.73.238`	trong C1	**Đã bị dùng thành công** [MEM]	—	—	❌
C3	Token remote trong `.git/config` của các site	`/var/www/*/.git/config`	**Đã bị đọc** [MEM]	—	—	❌
C4	Biến CI/CD GitLab (group ons-uni/lms, ons-lms), deploy token, runner token	GitLab	**Nghi lộ** (giả thuyết: 108 key là dump biến CI)	—	—	❌🔍
C5	Secret trong `/opt/*/.env`, docker-compose tmu	`/opt/`	**Đã bị đọc** [MEM]	—	—	❌
C6	Mật khẩu DB của từng site (`config.php`, `autolms/.../database.php`, `lipe/.../database.php`)	`/var/www/<site>/`	**Khả năng cao lộ** (`www-data` đọc được 10 ngày)	`chmod 640` các file config (24/10 16:20). Biện pháp này không chặn được `www-data` vì group vẫn là `www-data`.	—	❌
C7	`$CFG->passwordsaltmain` và các secret khác trong `config.php`	như C6	Khả năng cao lộ	—	—	❌
C8	MySQL	server DB ngoài	Mật khẩu bị dùng để thử đăng nhập;	—	—	❌🔍

	`dtw_26@27.71.21.34`		**chưa rõ có thành công không**			
C9	MySQL `stw3-be@27.71.21.176:63306`	server DB ngoài	Như C8	—	—	❌🔍
C10	Tài khoản Airflow (`admin`, `airflow`, `dtw`...; Airflow nào thì chưa rõ)	—	Bị thử mật khẩu; `af_win.ck` cho thấy có thể một cặp đã đăng nhập được. Có mẫu mật khẩu yếu theo tên công ty.	Xoá file `.ck` (đây chỉ là xoá bằng chứng, không phải thu hồi)	—	❌
C11	Phiên autolms giả tạo ra trước khi chặn `set_login`	session PHP / CodeIgniter	Có thể vẫn dùng được	Restart FPM không xoá session. **12.7b chưa chạy.**	—	❌
C12	Cookie `autolms_data` (cơ chế)	—	Vẫn giả được nếu mở lại `set_login`	Chặn `set_login` 403 (TẠM THỜI)	Dev chưa vá	❌
C13	Tài khoản admin/ user Moodle	DB các site	Có thể bị tạo hoặc đổi (kẻ tấn công có mật khẩu DB)	12.7c / 3.5c **chưa chạy**	—	— CHƯA CÓ DỮ LIỆU
C14	Mật khẩu người dùng HAUI (trong dump)	`/data/lmshaui_20261013.sql`	**Đã bị đọc**	—	Chưa buộc đổi mật khẩu	❌
C15	SSH root, `deploy`, `minhvd`, `dev01` trên máy này	`/root/.ssh` (ALO đã xoá 23/10 17:25), `/home/*`	Không có bằng chứng bị đọc (không có root)	Xoá `/root/.ssh`	—	🟡 Runbook vẫn khuyến nghị đổi khi dựng lại
C16	Token công cụ dev của root (Claude, Cursor, Gemini, Docker, gh, NetBird setup key)	`/root/*`	Không có bằng chứng bị đọc (`/root` là 700, không thấy dấu hiệu root)	—	—	❌ khuyến nghị đổi khi dựng lại
C17	`.mcp.json`, `.cursor/` ở ftu	đã chuyển `/root/ftu-moved`	`www-data` đọc được trong 10 ngày; grep không thấy tên biến bí mật	Chuyển khỏi web root	—	🟡 cần mở xem thủ công (không dán nội dung)
C18	`proxy_node_deploy_ed25519`, `/root/.dsh/...`	Không có trên máy (12.1)	Tên xuất hiện trong IOC của kẻ tấn công; có thể là key ở máy khác	—	—	🔍

5. CÁC HỆ THỐNG VÀ THÀNH PHẦN ĐÃ KIỂM TRA

Thành phần	Đã kiểm tra gì / phương pháp	Kết quả	Thời điểm	Chưa kiểm tra

File webshell	`find` theo tên, `stat` birth/mtime/ctime (5a)	9 loader + 9 payload, birth 14/10 00:20:09–00:20:51	23/10, 24/10	Payload haui/tmu không ghi birth
PHP bị chèn	git status, grep chữ ký `LC_ALL=C -a`, so md5 chéo 8 site, ctime > mtime (10d–10d4)	Không thấy	23/10 [MEM]	vendor/, node_modules; site không có git chỉ được so chéo
Code đổi sau 13/10	`find -newerct '2026-10-13 23:00'`	Chỉ có đợt root ở bav (15:45) và f350 haui	24/10 15:04	—
Persistence root	`ld.so.preload`, `dpkg --verify`, PAM, `.bashrc`, passwd/shadow, systemd, cron.d (10b/10f/10g)	Không thấy dấu hiệu; runbook ghi các thay đổi đều giải thích được	23/10 [MEM]	Chi tiết xác nhận NetBird (`wt0`), `face_recognition.service`, passwd `minhvd` (14/10), cron.d bav/nau/qbu (14/10) — CHƯA CÓ DỮ LIỆU; chưa kiểm tra rootkit mức kernel ngoài `lsmod`
Owner công cụ/key	`stat`, `find` (12.1)	Tất cả thuộc `www-data` → không thấy dấu hiệu root	24/10 02:28	—
Tiến trình	`ps` (verify)	Chỉ có nginx worker, php-fpm	24/10 13:26	Các lần sau
Cron/systemd/at	verify mục B	0 mới từ 23/10 20:00	24/10 13:26	crontab riêng `www-data` sau 15:30
SSH	`authorized_keys` đổi (verify)	0	24/10 13:26	auth.log `Accepted` từ 13/10 trên máy này
nginx	`nginx -T`, curl từng vhost, `grep -L set_real_ip_from`	11 bom + staff-lms trả 403 cho upload/import/set_login; mọi vhost có realip; deny 12 IP đã nạp	24/10 13:26–15:55	16 vhost `api-*` và gp26 **không** include ir-block
Log nginx	zgrep theo endpoint, IP, byte	Đường vào duy nhất là ftu; 60 hit loader 23/10 16:08–16:17	24/10	Log trước khi xoay vòng (nếu có); log của proxy 103.252.72.136
Log C2	`journalctl -k	grep IR_C2`	5 dòng, cho là curl test lúc 01:26	24/10 13:26	
Egress	iptables LOG `IR_WWW_OUT` → đích hợp lệ	Chỉ `14.225.31.78:443` (`vcruni1.onschool.edu.vn`) và `103.252.73.180:443` (`oaa-apigw-stg.onschool.edu.vn`), gọi mỗi 5 phút	24/10 15:00–15:25	IPv6 (ip6tables)
PHP	php.ini 7.4 có `disable_functions`; thêm vào pool	`php-fpm -t` ok cho 7.4, 8.2	24/10 15:21	Giá trị thực tế khi chạy; `open_basedir`
Mount	`mount	grep noexec`	7 dòng noexec (mount chồng)	24/10 15:22	
Quyền file	`find -user www-data -name '*.php'`	0 ở cả 11 site	24/10 16:20	Test chức năng các site khác nau
Git repo trên máy	git status, `.git/logs` owner	`.git/logs` thuộc `www-data` → git đang chạy dưới `www-data`	24/10 15:32	`.git/hooks`; lịch sử commit lạ
Database Moodle	—	**Chưa chạy** (3.5c/12.7c)	—	toàn bộ

Session	—	**Chưa chạy** (12.7b)	—	toàn bộ
moodledata	—	**Chưa quét** PHP/`.htaccess` trong `/var/moodledata/<site>`	—	toàn bộ
Docker	—	— CHƯA CÓ DỮ LIỆU (root có Docker)	—	container, image
GitLab / CI/CD / runner	—	**Chưa kiểm tra** (ngoài phạm vi máy)	—	audit log, token, biến CI, commit, webhook
3 máy bị lan sang	—	**Chưa kiểm tra** (12.5)	—	toàn bộ
MySQL 27.71.21.34, 27.71.21.176	—	**Chưa kiểm tra** (12.4b)	—	toàn bộ
Airflow	—	**Chưa kiểm tra**	—	toàn bộ
Production autolms	—	**Chưa kiểm tra** (ALO không quản prod)	—	toàn bộ
Proxy 103.252.72.136	—	**Chưa kiểm tra**	—	log + tính toàn vẹn
Bằng chứng	`sha256sum -c SHA256SUMS`	0 dòng FAIL	24/10 13:26	Bản sao ngoài máy của các file sau 02:35

6. CÁC BIỆN PHÁP ĐÃ ÁP DỤNG

#	Vấn đề	Hành động	Phạm vi	Bằng chứng thực hiện	Xác minh	Trạng thái	Loại	Có thể bị đảo ngược	Rủi ro còn lại	Bước tiếp
B1	Giữ bằng chứng	`ps`, `ss`, `pro c_a ll`, crontab, `web she lls .tg z`, `tmp .tg z`, `gly ph.`	`$IR`	Lời ALO + output 12.2	`sha256sum -c` 0 FAIL (13:26)	✅ / 🟡	—	Có (nằm trên máy bị chiếm)	Loader gốc đã mất trước khi đóng gói; `glyph.tgz` chứa private key; chưa xác nhận scp các file mới	scp bổ sung, lưu mã hoá

		`tgz`, `log s.t gz`, `SHA 256 SUM S`, scp ra ngoài; bổ sung `ses s_p ayl oad .tg z`, `jou rna l_s inc e_1 012 .tx t`, `$IR /` `pay loa d/`									
B2	Webshell và lỗ upload	`sni ppe ts/ ir- blo ck. con f`: 403 cho `plg _ca che *.p hp`, `fon`	cache	sess	idx)_<8>.(jpg	bin	log	png	gif	dat)`	

		`t_*` `.wo` `ff2`, `gki` `z04` `5m`, PHP trong `aut` `olm` `s/` `upl` `oad` `/`, `osp` `/` `imp` `ort`, `set` `_lo` `gin`, `cac` `he_` `*.b` `in`, `(img								
B3	IP kẻ tấn công	12 dòng `den` `y` trong `ir-` `blo` `ck.` `con` `f`	như B2	output 08:16Z	`nginx -t` ok. Chưa curl thử với IP bị deny.	🟡	TẠM THỜI	Có	Kẻ tấn công đổi IP rất dễ; api-* không có	Chặn ở proxy/biên
B4	C2 ra ngoài	iptables OUTPUT LOG +DROP `180` `.93` `.16`	máy này	verify PASS	curl test thất bại (01:26)	✅	TẠM THỜI	Có	C2 đổi IP/domain	Chặn ở biên + máy khác

		`0.36` và cổng 31443; `/etc/hosts` `0.0.0.0 d.zzkefa.com`								
B5	C2 vào	iptables INPUT `-s 180.93.160.36 -j DROP`	máy này	10a	**Không có tác dụng**, vì mọi kết nối vào đều đi qua proxy	⚠️ vô hiệu	—	—	—	Chặn ở proxy
B6	Lưu iptables khi reboot	`apt install iptables-persistent`; `netfilter-persistent`	máy này	output có `25-ip6tables save`	`grep -c 180.93.160.36 /etc/iptables/rules.v4` **chưa có output**	🟡	VĨNH VIỄN (nếu lưu đúng)	Có	**apt đã gỡ 1 gói, chưa biết gói nào** (nghi `ufw`)	Kiểm tra `dpkg.log`, `rules.v4`

		`t` `sav` `e`								
B7	Egress `www-data`	ACCEPT `lo`, ESTABLISHED, 10/8, 127/8, `14.` `225` `.31` `.78` `:44` `3`, `103` `.25` `2.7` `3.1` `80:` `443`, DNS 53; LOG; REJECT	máy này, user `www-data`	output 08:31Z	`curl oaa-apigw` 404 (được phép), `example.com` 000 (bị chặn)	✅	VĨNH VIỄN (nếu B6 ổn)	Có	IPv6 chưa chặn; DNS mở ra mọi đích; 10.0.0.0/8 mở (mạng nội bộ); root/deploy không bị giới hạn	ip6tables; thu hẹp 10/8
B8	Chạy lệnh từ PHP	`php` `_ad` `min` `_va` `lue` `[di` `sab` `le_` `fun` `cti` `ons` `] =` `exe` `c,s` `yst` `em,` `pas`	PHP-FPM 7.4, 8.2	output 08:23Z	`php-fpm -t` ok; giá trị thực tế **chưa kiểm tra**	🟡	VĨNH VIỄN (cấu hình)	Có	Danh sách thiếu `putenv`, `mail`, `dl` (đường vượt kiểu LD_PRELOAD); chưa có `open_basedir`; mọi site chung user	Bổ sung + kiểm tra

		`sthru,shell_exec,proc_open,popen,pcntl_exec` mọi pool; php.ini 7.4 đã có								
B9	Chạy file từ thư mục tạm	noexec, nosuid, nodev `/tmp`, `/var/tmp`, `/dev/shm` + `/etc/fstab`	máy này	output 08:23Z	`mount` đếm 7 noexec	✅ hiện tại / 🟡 sau reboot	VĨNH VIỄN (fstab)	Có	Chưa chạy `systemctl daemon-reload`; moodledata và `autolms/application/cache` vẫn ghi được và không có noexec	daemon-reload, test reboot
B10	Code ghi được bởi `www-data`	`fix():deploy:www-`	11 site	output 09:20Z	0 file PHP thuộc `www-data`; nau: `touch index.php` → Permission denied	✅	VĨNH VIỄN (nếu giữ quy trình)	**Có:** deploy bằng root hoặc	`getfacl` backup rỗng (20 B); tvu26 không có bản lưu quyền; chỉ test chức năng ở nau	Dev deploy bằng `sudo -u deploy`; thêm kiểm tra owner vào ir-watch

		`data`, 755/644; chỉ `autolms/application/cache` (8 site) và `autolms/upload` (econi) cho `www-data` ghi; config 640						`www-data` sẽ đổi lại		
B11	Tiến trình kẻ tấn công	kill tiến trình lạ của `www-data`, lưu `$IR/killed/`	máy này	Lời ALO	verify: không còn tiến trình lạ	✅	—	—	—	—

B12	Công cụ tấn công	Xoá `/tmp/af*`, `ks*`, `dag.json`, `.sysli bs`	máy này	output 08:23Z	`ls` trống	✅	VĨNH VIỄN	—	Bản sao vẫn nằm trong `tmp.tgz` (bằng chứng)	—
B13	Payload	Lưu, `chmod 000`, xoá 6 payload; `sess_ahmxcasd.log` chỉ `chmod 000`	7 site	output 08:50Z	`rm` không lỗi	✅ 6 / 🟡 1	VĨNH VIỄN	—	`sess_ahmxcasd.log` có thể còn và đã bị `fix` đổi về 644	Xoá + kiểm tra
B14	Tài liệu nội bộ trong web root	Chuyển sang `/root/ftu-moved`	ftu	output 08:38Z	—	✅	VĨNH VIỄN	—	Có thể đã bị đọc	Xem `.mcp.json`
B15	Giám sát	Cron `/etc/cron.d/`	máy này	output 08:23Z	**Chưa xác nhận** file log được tạo	🟡	VĨNH VIỄN	Có	Không có auditd; log nằm trên chính máy này	auditd, gửi log ra ngoài

		`/ir-watch` (10 phút, ghi PHP mới vào `/var/log/ir-newphp.log`); khối verify `$IR/verify_*.txt`; LOG iptables								
B16	Chặn `set_login`	Rule 403 trong ir-block	như B2	ALO thấy 403 trên trình duyệt (16:47)	✅	✅	**TẠM THỜI** (chờ dev vá HMAC)	Có	Đăng nhập autolms trên staging bị hỏng; code vẫn lỗi	Dev vá
B17	realip	`set_real_ip_from 103.252.7`	mọi vhost	`grep -L` rỗng	✅	✅	VĨNH VIỄN	Có	—	—

`2.1`
`36`

7. CÁC BIỆN PHÁP CHẶN VÀ PHẠM VI HIỆU LỰC

Biện pháp	Đối tượng	Vị trí	Hiệu lực thực tế / phạm vi	Thời hạn	Cách kiểm tra	Khả năng bị vượt hoặc xoá
nginx path block (`ir-block.conf`)	URL webshell, upload PHP, `osp/import`, `set_login`, mẫu tên payload	nginx trên `bom-stg-all2`	11 vhost bom + staff-lms. **Không áp dụng** cho 16 vhost `api-*` và `bom-gp26`.	Tạm thời, đến khi vá code và dựng lại	`curl -H "Host: <vhost>" http://127.0.0.1/autolms/index.php/login/login/set_login` → 403	Đổi tên file hoặc dùng đường upload khác thì vượt được. Root xoá được. Vhost mới quên include sẽ không được bảo vệ.
nginx `deny` 12 IP	`61.124.1.29`, `180.93.160.36`, `158.247.235.77`, `43.133.21.174`, `149.104.87.114`, `216.26.248.185`, `209.50.185.67`, `209.50.185.220`, `209.50.185.180`, `104.207.58.243`, `103.76.182.40`, `141.227.135.167`	nginx (trong `ir-block.conf`)	Như dòng trên. Dựa vào realip, nên chỉ đúng khi request đi qua proxy `103.252.72.136`.	Tạm thời	`nginx -T`	grep -c 'deny 180.93.160.36'` ⩾ 1
iptables OUTPUT C2	`180.93.160.36`, cổng 31443	kernel trên máy này	Mọi user trên máy	Lâu dài nếu `rules.v4` đúng (🟡)	`iptables -S OUTPUT`	grep 180.93.160.36`
`/etc/hosts` sinkhole	`d.zzkefa.com`	máy này	Chỉ áp dụng khi phân giải qua hệ thống	Lâu dài	`getent hosts d.zzkefa.com` → `0.0.0.0`	Vượt bằng IP trực tiếp, DNS riêng, hoặc domain khác
iptables egress `www-data`	Mọi đích ngoài 2 dịch vụ công ty + DNS + 10/8	máy này	Chỉ user `www-data`, chỉ IPv4	Lâu dài nếu lưu đúng	`sudo -u www-data curl -m5 https://example.com` → 000	DNS tunneling; IPv6; mạng 10/8; tiến trình chạy dưới user khác
iptables INPUT `-s 180.93.160.36`	C2	máy này	**Không có tác dụng** (traffic vào đi qua proxy)	—	—	—
Chặn ở proxy `103.252.72.136` / firewall biên / cloud / DNS	—	—	**CHƯA ÁP DỤNG** (— CHƯA CÓ DỮ LIỆU)	—	—	—

Chặn trên 3 máy bị lan sang, PRO DNU/NAU, server khác	—	—	**CHƯA ÁP DỤNG**	—	—	—
GitLab (thu hồi token/ key)	—	—	**CHƯA ÁP DỤNG**	—	—	—

Kết luận mục 7: mọi biện pháp chặn hiện chỉ nằm **tại một điểm** là chính máy `bom-stg-all2`. Chưa có lớp chặn nào ở biên mạng, proxy, DNS, GitLab hay các máy khác, nên **không thể coi là chặn lâu dài**.

---

8. NGUYÊN NHÂN GỐC VÀ LỖ HỔNG

8.1 Nguyên nhân ban đầu (ĐÃ XÁC MINH)

Lỗ	Chi tiết	Bằng chứng
L1: Bỏ qua xác thực ở `set_login`	`login.php` → `set_login()` lấy cookie `autolms_data`, chỉ base64 + JSON decode rồi tạo phiên với `user_id` và `shortname` (role) do client gửi. Không có chữ ký và không mã hoá (dòng `decodeId` bị comment).	Mã nguồn 12.3b (ftu)
L2: Upload không giới hạn trong web root	`osp.php` → `import()` : `allowed_types="*"`, `upload_path="upload"` (nằm trong web root). Thư mục cho phép chạy PHP.	Mã nguồn 12.3b; 7b; log `ft9.php`
Phạm vi code dính lỗi	`login.php` md5 `6ce6943d25c9` giống nhau ở dnu, ecouni, ftu, haui, nau, tmu. bav, qbu dùng bản khác (`eab209760cc6`), chưa đánh giá. Kẻ tấn công chỉ thành công ở ftu; ở các site khác họ nhận 38 byte (có thể do cookie gửi sai).	md5 + `12_3a2.txt`

8.2 Yếu tố giúp lan rộng và duy trì quyền (ĐÃ XÁC MINH)

- Mọi site dùng chung user `www-data`, và gần như toàn bộ code thuộc `www-data` (khoảng 20.000 file PHP mỗi site). Vì vậy một lỗ ở ftu ghi được loader sang cả 9 site. (Đã khắc phục ở B10.)
- `disable_functions` chưa bật ở pool FPM (đã khắc phục một phần ở B8).
- Không giới hạn egress, nên máy đò SSH và MySQL ra ngoài được (đã khắc phục ở B7).
- `/tmp` cho phép chạy file (đã khắc phục ở B9).
- Có private key, dump DB, token git và `.env` mà `www-data` đọc được trên máy.
- Không có giám sát toàn vẹn file hay auditd. Webshell tồn tại 10 ngày mà không bị phát hiện.
- Git chạy dưới `www-data` (`.git/logs` thuộc `www-data`).

8.3 Giả thuyết và dữ liệu còn thiếu

Giả thuyết	Hiện trạng
108 key là dump biến CI/CD GitLab	Dựa trên tên file. Chưa có audit log GitLab. 🔍

Liên quan sự cố trước (runner `phongbx`, cùng IP `61.124.1.29`)	Trùng IP. Chưa đối chiếu. 🔍
Ban đầu từng nghi đường vào là GitLab → deploy.sh	Đã **loại trừ** cho bước ghi webshell (ghi qua web dưới `www-data`), nhưng **chưa loại trừ** việc GitLab bị chiếm ở mức tổ chức.
Attacker vào được ftu mà không vào được các site khác dù cùng code	Chưa rõ nguyên nhân (có thể do cấu hình cookie hoặc dữ liệu riêng của ftu). 🔍

8.4 Đường xâm nhập khác chưa được loại trừ

- `setting_lipe.php` (haui, tmu) có import CSV qua `$_FILES`.
- 16 vhost `api-*` không có ir-block và chưa được đánh giá.
- `login.php` bản `eab209760cc6` ở bav, qbu.
- Phiên giả còn sống (12.7b).
- Tài khoản Moodle admin hoặc cấu hình `pathto*` bị cài qua DB (3.5c).
- Token GitLab đã lộ có thể dùng để đẩy code độc, và lần `git pull` sau sẽ tái nhiễm.
- Key trong `.glyph` vẫn có hiệu lực trên các server khác.

---

9. PHẠM VI ẢNH HƯỞNG VÀ RỦI RO CÒN LẠI

Đối tượng	Ảnh hưởng	Mức chắc chắn	Đánh giá
`bom-stg-all2`	Thực thi mã dưới `www-data` trong 10 ngày	✅	Đã giảm mạnh; không chứng minh được sạch 100% (runbook: đích cuối là dựng lại)
Dữ liệu cá nhân HAUI (`/data/lmshaui_20261013.sql`)	Đã bị đọc; chưa biết có bị tải ra ngoài không	✅ đọc / 🔍 tải ra	**Nguy hiểm.** Theo NĐ 13/2023/NĐ-CP có thể phải thông báo trong 72 giờ (cần pháp chế xác nhận). Đã báo hay chưa: — CHƯA CÓ DỮ LIỆU
DB các site staging	Có mật khẩu DB → có thể đọc hoặc sửa	Khả năng cao	Chưa kiểm tra
`root@103.252.72.221`, `root@103.252.73.52`, `dev01@103.252.73.238`	Đã bị chạy lệnh	✅ [MEM]	**Nguy hiểm, chưa xử lý**
MySQL `27.71.21.34`, `27.71.21.176:63306`	Bị thử đăng nhập	✅ thử / 🔍 kết quả	Chưa xử lý
Airflow	Có thể đã bị đăng nhập	🔍	Chưa xử lý
GitLab + CI/CD	Token đã lộ; nghi biến CI bị dump	🔍	**Nguy hiểm**, chưa kiểm tra
Production autolms (DNU, NAU, các trường khác)	Cùng lỗ `set_login` + `osp/import`; có key node PRO trong `.glyph`	Khả năng cao	**Nguy hiểm**, ngoài quyền quản lý của ALO, chưa báo
Mã nguồn	Không thấy PHP bị chèn; `config.php`, JS build, plugin `onschoolliveclass` chưa xác nhận	🔍	Cần dev xác nhận

Người dùng cuối	JS `amd/build` chưa được đối chiếu	🔍	Thấp – trung bình

Khả năng tái xâm nhập: cao nếu chưa xoay vòng bí mật. Kẻ tấn công vẫn giữ các key SSH, token git và mật khẩu DB; họ có quyền trên 3 máy khác và có hạ tầng C2 riêng.

Dấu hiệu cần theo dõi trong log:

- nginx: 403 vào `set_login`, `osp/import`, `/autolms/upload/*.php`, `plg_cache*`, `(img|cache|sess|idx)_<8>.*` từ IP lạ; request có UA `curl/8.0` hoặc `curl/8.14.1`; POST vào file PHP lạ.
- kernel: `IR_C2_OUT`, `IR_C2_UID`, `IR_31443_OUT`, `IR_WWW_OUT` (đích mới).
- `/var/log/ir-newphp.log`: file PHP mới hoặc vừa đổi.
- File PHP thuộc `www-data` xuất hiện lại ngoài `autolms/application/cache`.
- `auth.log` trên các máy có key bị lộ: `Accepted publickey` từ 10.0.10.128 hoặc từ IP lạ.
- Moodle: user hoặc admin mới, `config_log` đổi.
- Proxy 103.252.72.136: các IP ở mục 7.

---

10. DANH SÁCH CÔNG VIỆC

Ký hiệu: ✔ đã hoàn thành · ☐ đề xuất, chưa làm.

P0 – Nguy cơ đang tồn tại, cần xử lý ngay

#	Mục tiêu	Hành động	Hệ thống	Hoàn thành khi	Xác minh
☐ P0-1	Vô hiệu key bị lộ	Lấy fingerprint 108 key (từ `glyph.tgz`, làm trên máy sạch); gỡ public key khỏi `authorized_keys` trên mọi server, ưu tiên PRO DNU/NAU; tạo key mới	Mọi server, GitLab	0 server còn chấp nhận key cũ	`ssh-keygen -lf authorized_keys`
☐ P0-2	Khoanh vùng 3 máy bị lan sang	Chặn C2, chạy 12.5, lưu bằng chứng, đổi bí mật, dựng lại	`103.252.72.221`, `103.252.73.52`, `103.252.73.238`	Đã cách ly hoặc dựng lại	Output 12.5 + xác nhận người quản lý
☐ P0-3	Thu hồi token GitLab và biến CI	Thu hồi token trong `.git/config`, deploy token/key, runner token; đổi biến CI group ons-uni/lms, ons-lms; xem audit log từ 13/10	GitLab	Token cũ trả 401	Audit log + thử token cũ
☐ P0-4	Đổi mật khẩu MySQL ngoài	Đổi `dtw_26`, `stw3-be`; giới hạn host; tra log kết nối từ 14/10	27.71.21.34, 27.71.21.176	Đổi xong, có kết quả log	12.4b
☐ P0-5	Airflow	`airflow users reset-password` cho mọi user; tra log đăng nhập từ 13/10; bỏ mật khẩu yếu dạng mặc định trên toàn công ty	Máy Airflow	Đổi xong + biết tài khoản nào bị trúng	Log đăng nhập Airflow
☐ P0-6	Đổi secret `/opt/`	Đổi mật khẩu DB từng site (DB + config),	`bom-stg-all2`, DB	Đổi xong	Đăng nhập DB bằng mật

	`*/.env` và DB staging	`passwordsaltmain`, SMTP, API			khẩu cũ thất bại
☐ P0-7	Báo người quản production	Gửi thông báo về lỗ `set_login` / `osp/import` (md5 `login.php`) và key node PRO bị lộ; đề nghị chặn 2 endpoint ở nginx	Production	Có xác nhận đã nhận	—
☐ P0-8	Nghĩa vụ pháp lý về dữ liệu cá nhân	Báo pháp chế/lãnh đạo về dump HAUI; quyết định thông báo theo NĐ 13/2023 (72 giờ); buộc người dùng HAUI đổi mật khẩu	Pháp chế, HAUI	Có quyết định bằng văn bản	—
☐ P0-9	Huỷ phiên giả	Chạy 12.7b, xoá session autolms/PHP cũ	`bom-stg-all2`	0 session tạo trước 24/10 02:46	Đếm file session

P1 – Cần hoàn tất để xác nhận kiểm soát

#	Mục tiêu	Hành động	Hoàn thành khi / xác minh
☐ P1-1	Moodle DB sạch	Chạy 12.7c / 3.5c cho từng site (user mới, `siteadmins`, role manager, `config_log`, `task_adhoc`, `pathto*`)	Dán số đếm; không có id lạ
☐ P1-2	iptables còn sau reboot	`grep -c 180.93.160.36 /etc/iptables/rules.v4`; `iptables-save`	grep -c uid-owner`
☐ P1-3	Biết gói apt đã gỡ	`grep -E ' remove | purge ' /var/log/dpkg.log	tail`
☐ P1-4	fstab	`systemctl daemon-reload`; kiểm tra ở lần reboot có kế hoạch	`findmnt -no OPTIONS /tmp` có noexec
☐ P1-5	Dọn sót	`rm -f /var/www/inu26/public/sess_ahmxcasd.log`, `nau/.../controllers/test.php`; xác nhận `.glyph` không còn	`find / -xdev \( -name 'sess_*.log' -o -name .glyph \) ! -path '/var/lib/php/*'` rỗng
☐ P1-6	`disable_functions` có hiệu lực	Kiểm tra pool (`grep 'php_admin_value\[disable_functions\]' pool.d/*.conf`) và giá trị runtime	Mọi pool có
☐ P1-7	Xác nhận thay đổi trong thời gian bị chiếm	Dev xác nhận: config.php ecouni/ftu/haui (20–22/10), JS `amd/build` inu26/tvu26, plugin `onschoolliveclass`, deploy bav 23/10 15:45	Có xác nhận hoặc diff với bản sạch
☐ P1-8	C2 log	`journalctl -k --since '2026-10-23 20:00'	grep IR_C2`
☐ P1-9	102 lượt qua proxy	Tra log proxy `103.252.72.136` ngày 23/10 tìm IP thật; kiểm tra tính toàn vẹn proxy	Có danh sách IP
☐ P1-10	Các dải bị dò	Grep `Accepted` từ 10.0.10.128 trên 103.252.72–74.x, 10.0.2.x, 10.0.3.233, 10.0.10.x, 192.168.0.x	Không có dòng nào
☐ P1-11	Bằng chứng	scp các file sau 02:35 (payload, `syslibs_left.tgz`, `verify_*`, `perm_before.txt.gz`); lưu mã hoá `glyph.tgz`	Có bản sao + hash khớp
☐ P1-12	Dựng lại máy (mục 11 runbook; điều kiện đóng sự cố 12.6)	Máy mới, code từ commit đã đối chiếu, vá trước khi mở Internet	ALO **chưa quyết định**; hiện đang cứng hoá tại chỗ
☐ P1-13	Quét moodledata	`find /var/moodledata -name '*.php' -o -name '*.phtml' -o -name '.htaccess' -o -name '.user.ini'`	Rỗng

☐ P1-14	Kiểm tra chức năng sau đổi quyền	Test các site ngoài nau (đăng nhập, khoá học, upload)	Không có `Permission denied`

P2 – Gia cố, giám sát, phòng ngừa

#	Mục tiêu	Hành động
☐ P2-1	Vá code autolms	`set_login`: HMAC-SHA256 + `hash_equals`, hạn ngắn, dùng một lần, lấy role từ DB. `osp/import`: chỉ `xls
☐ P2-2	Cô lập site	Mỗi site một pool FPM và một user; `open_basedir`; bổ sung `putenv`, `mail`, `dl` vào `disable_functions`
☐ P2-3	Phủ đủ nginx	Include ir-block (hoặc bản phù hợp) cho `api-*` và gp26; chặn chạy PHP trong mọi thư mục ghi được
☐ P2-4	Egress	ip6tables cho `www-data`; thu hẹp 10/8; giới hạn DNS về resolver nội bộ
☐ P2-5	Chặn nhiều lớp	Chặn IP/domain C2 ở proxy, firewall biên và các server cùng mạng
☐ P2-6	Giám sát	Cài auditd (`-w /var/www -p wa`), gửi log ra máy riêng, FIM (AIDE); thêm kiểm tra "file PHP thuộc www-data = 0" vào ir-watch
☐ P2-7	Quy trình deploy	Chỉ `sudo -u deploy git pull`; không giữ dump DB, private key hay tài liệu nội bộ trong web root hoặc nơi `www-data` đọc được
☐ P2-8	Chính sách mật khẩu	Bỏ mật khẩu mặc định/yếu; MFA cho GitLab, Airflow

Đã hoàn thành (để đối chiếu): ✔ giữ bằng chứng · ✔ chặn nginx 11 vhost + staff-lms · ✔ deny 12 IP · ✔ realip · ✔ chặn C2 trên máy · ✔ kill tiến trình · ✔ xoá công cụ /tmp, `.syslibs` · ✔ xoá 6 payload · ✔ noexec · ✔ egress `www-data` · ✔ đổi owner code 11 site · ✔ chuyển tài liệu ftu · ✔ disable_functions (🟡 chưa kiểm tra runtime) · ✔ cron ir-watch (🟡 chưa kiểm tra chạy).

---

11. TRẠNG THÁI BẢO MẬT CUỐI CÙNG

Đã xử lý, có bằng chứng

- Loader, payload (8/9 đã xoá, 1 chưa xác nhận) và công cụ tấn công trên `bom-stg-all2`.
- Đường vào `set_login` và `osp/import` bị chặn 403 ở 11 vhost bom + staff-lms.
- `www-data` không còn ghi được code (0 file PHP ở 11 site).
- `www-data` không còn gọi ra Internet tuỳ ý (đã test).
- Không thấy dấu hiệu kẻ tấn công lên root; không thấy mã độc quay lại tính đến 24/10 13:26.

Đã giảm nhưng chưa loại bỏ

- Lỗ ứng dụng: mới chặn tạm ở nginx, code chưa vá.
- Thực thi PHP độc nếu có lỗ mới: đã giảm nhờ `disable_functions`, noexec, egress, quyền file; còn hở `putenv` / `mail`, chưa có `open_basedir`, các site vẫn chung user.
- Chặn C2/IP: chỉ tại một điểm.

Chưa xử lý hoặc chưa thể kết luận

- Toàn bộ xoay vòng bí mật (C1–C14).
- 3 máy bị lan sang; 2 MySQL; Airflow; GitLab/CI; production; proxy.
- Dữ liệu cá nhân HAUI và nghĩa vụ thông báo.
- Session giả; Moodle DB; moodledata; vhost `api-*`.
- Gói bị apt gỡ; iptables và fstab sau reboot; trạng thái `.glyph` và `sess_ahmxcasd.log`.

Hệ thống cần tiếp tục giám sát: `bom-stg-all2` (log nginx, kernel log, `ir-newphp.log`), 3 máy bị lan sang, mọi server có key trong `.glyph`, 2 MySQL, Airflow, GitLab, proxy `103.252.72.136`, production autolms.

Điều kiện còn thiếu để tuyên bố đã xử lý hoàn toàn (theo runbook 12.6):

1. Mọi bí mật ở mục 4 đã được thu hồi hoặc đổi tại nguồn.
2. 3 máy bị lan sang đã được cách ly hoặc dựng lại; các dải bị dò đã kiểm tra `Accepted`.
3. Code autolms đã vá; máy staging đã dựng lại (hoặc có quyết định chấp nhận rủi ro bằng văn bản).
4. GitLab đã được kiểm tra và không có commit, webhook hay pipeline lạ.
5. 7 ngày liên tục không có: 403 từ IP lạ vào đường đã chặn, kết nối tới C2, đăng nhập SSH bằng key cũ.
6. Đã xử lý nghĩa vụ dữ liệu cá nhân.

→ Sự cố CHƯA được xử lý hoàn toàn.

---

12. BẰNG CHỨNG VÀ PHỤ LỤC

12.1 Vị trí bằng chứng

Bằng chứng	Vị trí	Ghi chú
Thư mục IR	`/root/ir/20261023-2211/` trên `bom-stg-all2`	ALO cho biết đã scp bản sao ra ngoài (lần đầu)
Trạng thái sống	`ps.txt`, `ss.txt`, `proc_all.txt`, `crontabs.txt`, `$IR/killed/`	Theo runbook trước của ALO
Gói	`webshells.tgz`, `tmp.tgz` (gồm `.syslibs`, công cụ /tmp), `glyph.tgz` (**có private key**), `logs.tgz`, `moodlelib.tgz`	—
Payload	`$IR/payload/woff2.tgz`, `*.decoded.txt`, 6 payload chép ngày 24/10	—
Bổ sung	`sess_payload.tgz` (`271f86c0…204b`), `sess_payload_stat.txt`, `journal_since_1012.txt` (`56097022…f6`), `syslibs_left.tgz`, `fstab.bak`, bản sao pool FPM, `perm_before.txt.gz` (574.000 dòng; **không gồm tvu26**), `perm_before.acl.gz` (**rỗng 20 B, không dùng được**)	—
Kết quả kiểm tra	`webshell_times.txt`, `12_1.txt`, `12_3a.txt`, `12_3a2.txt`, `12_3b_auth.txt`, `nginx_T.txt`, `verify_*.txt`	`webshell_paths.txt` **không tồn tại** (runbook cũ lỗi)

Hash	`$IR/SHA256SUMS`	Có thể chứa dòng cũ của `sess_payload.tgz` /journal; lệnh dọn đã được đưa, chưa thấy output
Tài liệu chuyển khỏi web root	`/root/ftu-moved/`	—
Runbook	`/mnt/project-files/ir/runbook-23-10.md`	—
Cấu hình chặn	`/etc/nginx/snippets/ir-block.conf`, `/etc/iptables/rules.v4`, `/etc/fstab`, `/etc/php/*/fpm/pool.d/*.conf`, `/etc/cron.d/ir-watch`, `/etc/hosts`	—

12.2 IOC

Loại	Giá trị
C2	`d.zzkefa.com` → `180.93.160.36` (HTTP 80 `/data/`, HTTPS 31443, cert tự ký)
IP tấn công (log)	`61.124.1.29` (xâm nhập ban đầu, trùng sự cố cũ), `180.93.160.36` (điều khiển 14–23/10), `103.76.182.40` (gọi webshell 23/10), `158.247.235.77` (thử tmu 16/10)
IP trong danh sách deny (nguồn: runbook trước)	`43.133.21.174`, `149.104.87.114`, `216.26.248.185`, `209.50.185.67`, `209.50.185.220`, `209.50.185.180`, `104.207.58.243`, `141.227.135.167`
IP chưa rõ	`49.51.33.159`
IP nội bộ công ty (không phải attacker)	`103.252.72.136` (reverse proxy), `14.225.31.78` (`vcruni1.onschool.edu.vn`), `103.252.73.180` (`oaa-apigw-stg.onschool.edu.vn`)
IP nghi của nhân viên (chưa xác nhận)	`116.96.47.x`, `116.96.46.141`, `183.80.188.171`, `42.113.92.169`, `117.5.147.175`
Đích di chuyển ngang	`root@103.252.72.221`, `root@103.252.73.52`, `dev01@103.252.73.238`, MySQL `dtw_26@27.71.21.34`, `stw3-be@27.71.21.176:63306`
User-Agent	`curl/8.14.1`, `curl/8.0`
Mẫu tên file	`plg_cache_<8>.php`, `font_<8>.woff2`, `cache_<8>.bin`, `img_<8>.jpg`, `sess_<8>.log`, `idx_<8>.dat`, `ft9.php`, `gkiz045m`; payload luôn 2566 byte
Thư mục	`/var/tmp/.syslibs/`, `*/autolms/application/cache/.glyph`, `/root/.ssh/proxy_node_deploy_ed25519` và `/root/.dsh/redteam/bdoor/v7` (tên trong IOC, không có trên máy)
Endpoint bị khai thác	`/autolms/index.php/login/login/set_login`, `/autolms/index.php/autocourse/osp/import`, `/autolms/upload/*.php`
Hash	Xem mục 3 (M13–M20)
Mã nguồn	`login.php` md5 `6ce6943d25c9…` (dnu, ecouni, ftu, haui, nau, tmu), `eab209760cc6…` (bav, qbu)
Inode loader (5a)	bav 11542264, haui 12333524, nau 12119860, qbu 11868181, tmu 12333527, dhv26 1048968, inu26 1310736, tvu26 566944, ftu 11083346

12.3 Mâu thuẫn và sai sót đã phát hiện trong quá trình xử lý

#	Nội dung	Kết luận đúng

1	Bản tóm tắt ngày 23/10 ghi log nginx theo giờ +07, "request đầu 13/10 17:20:10 +07"	Log cũ là UTC; lần ghi loader đầu tiên là 14/10 00:20:10 (+07)
2	Bản tóm tắt ngày 23/10 cho rằng đường vào là GitLab → deploy.sh	Bước ghi webshell đi qua web (`www-data`) ở ftu; GitLab vẫn là rủi ro riêng
3	Runbook ghi 2.2 " `ir-deny.conf` đã làm"	`conf.d` trống. Deny chỉ có hiệu lực từ 24/10 15:16 (gộp vào ir-block)
4	Ban đầu cho rằng site bị vào đầu tiên là bav	Là ftu
5	`IR_C2_OUT` lúc 01:26 bị báo động là beacon	Là curl kiểm tra
6	`.glyph` được nói là xoá lúc 20:50 ngày 23/10	12.1 lúc 02:28 ngày 24/10 vẫn thấy 108 file → thời điểm xoá chưa rõ, chưa xác minh
7	Lệnh `sed` thêm rule nginx có `{8}` không đặt trong ngoặc kép làm hỏng config (15:44)	Đã sửa, `nginx -t` ok, test 403 (15:55)
8	Khối kiểm tra trang chủ sau `fix` test nhầm vhost `api-*`	Chỉ nau được test đúng
9	Ưu tiên đối owner bị trì hoãn	ALO nhắc; đã làm 16:03–16:20
10	Khuyến nghị 12.7d có `putenv,dl` , nhưng lệnh thực tế áp dụng không có	Thiếu `putenv` , `dl` , `mail` (P2-2)

BẢNG TỔNG KẾT

HẠNG MỤC	TRẠNG THÁI	BẰNG CHỨNG	RỦI RO CÒN LẠI	HÀNH ĐỘNG TIẾP THEO
Xác định đường vào	✅ ĐÃ XÁC MINH	Log ftu 13/10 17:18–17:20 UTC; mã `set_login` / `osp.php`	Code vẫn lỗi ở mọi site cùng md5 và có thể ở production	Dev vá (P2-1); báo prod (P0-7)
Chặn đường vào trên staging	✅ ĐÃ XÁC MINH · TẠM THỜI	curl 403 ở 11 vhost + staff-lms	api-*, gp26 không có; vượt được bằng đường upload khác	P2-3; giữ đến khi vá
Gỡ loader + payload	✅ 17/18 · 🟡 `sess_ahmxcasd.log`	stat, sha256, `rm` , test 403	Payload inu26 có thể còn (644)	P1-5
Gỡ công cụ tấn công	✅ ĐÃ XÁC MINH	`ls` trống	Không rõ ai xoá phần chính của `.syslibs`	—
`.glyph` trên máy	🟡 CHƯA XÁC MINH	Lời ALO; mâu thuẫn thời điểm	Bản sao trong `glyph.tgz`	P1-5, lưu mã hoá
Persistence root	✅ không phát hiện (không chứng minh sạch)	10b/10g, 12.1	Rootkit kernel chưa kiểm tra sâu	Dựng lại (P1-12)
Quyền ghi code	✅ ĐÃ XÁC MINH · VĨNH VIỄN có điều kiện	0 file PHP `www-data` ; test nau	Deploy sai user sẽ đảo ngược; tvu26 không có backup quyền	P2-6, P2-7, P1-14
`disable_functions`	🟡 CHƯA XÁC MINH runtime	`php-fpm -t` ok	Thiếu `putenv` / `mail` / `dl` ; không có `open_basedir`	P1-6, P2-2
noexec	✅ hiện tại · 🟡 sau reboot	`mount`	moodledata/cache không có noexec	P1-4
Egress `www-data`	✅ ĐÃ XÁC MINH (IPv4)	curl 404 / 000	IPv6, DNS, 10/8	P2-4

Egress `www-data`	✅ ĐÃ XÁC MINH (IPv4)	can 104 / 000	IPv6, DNS, ICMP	P2-4
Chặn C2	✅ trên máy · TẠM THỜI	verify PASS	Một điểm; C2 đổi IP	P2-5
iptables lưu khi reboot	🟡 CHƯA XÁC MINH	`netfilter-persistent save` chạy	apt gỡ gói chưa rõ	P1-2, P1-3
Deny 12 IP	🟡 nạp OK, chưa test	`nginx -t`	Dễ vượt	P2-5
Giám sát	🟡 CHƯA XÁC MINH	Cron tạo xong	Không có auditd; log nằm trên máy bị chiếm	P2-6
Bằng chứng	✅ hash OK · 🟡 bản sao file mới	`sha256sum -c` 0 FAIL	Loader gốc đã mất	P1-11
Private key (108)	❌ CHƯA XỬ LÝ	12.1, 10e	**Đã dùng để vào 3 máy; vẫn hiệu lực**	P0-1
3 máy bị lan sang	❌ CHƯA XỬ LÝ	10e [MEM]	Root/sudo trong tay kẻ tấn công	P0-2
GitLab / CI / token git	❌ CHƯA XỬ LÝ · 🔍	`.git/config` bị đọc	Đẩy code độc, tái nhiễm	P0-3
MySQL ngoài (2)	❌ CHƯA XỬ LÝ · 🔍	10e [MEM]	Có thể đã truy cập DB	P0-4
Airflow	❌ CHƯA XỬ LÝ · 🔍	`af_win.ck`	Tài khoản có thể bị chiếm	P0-5
Secret DB staging, `.env`	❌ CHƯA XỬ LÝ	`www-data` đọc được 10 ngày	Truy cập DB	P0-6
Session giả	❌ CHƯA XỬ LÝ	12.7b chưa chạy	Phiên manager còn sống	P0-9
Moodle DB (admin/config)	— CHƯA CÓ DỮ LIỆU	12.7c chưa chạy	Admin cửa sau	P1-1
Dữ liệu cá nhân HAUI	❌ CHƯA XỬ LÝ	10e [MEM]	Pháp lý (NĐ 13/2023, 72 giờ)	P0-8
Production autolms	❌ CHƯA XỬ LÝ (ngoài quyền ALO)	md5 code chung; key PRO trong `.glyph`	Cùng lỗ, có thể đã bị khai thác	P0-7
Thay đổi trong thời gian bị chiếm (config, JS, plugin)	🔍 CẦN ĐIỀU TRA	stat ctime	Cửa sau hoặc mã độc phía client	P1-7
Proxy 103.252.72.136 / dải bị dò	🔍 CẦN ĐIỀU TRA	102 hit chưa rõ nguồn; dải bị dò SSH	Máy công ty khác bị chiếm	P1-9, P1-10
Gói apt bị gỡ	🔍 CẦN ĐIỀU TRA	Output apt bị cắt	Mất firewall cũ (nếu là `ufw`)	P1-3
Dựng lại máy	❌ CHƯA QUYẾT ĐỊNH	Runbook mục 11, 12.6	Không chứng minh được máy sạch	P1-12
Tổng thể sự cố	**KIỂM SOÁT MỘT PHẦN**	Các mục trên	**Tái xâm nhập cao nếu chưa xoay vòng bí mật**	Làm P0 theo thứ tự P0-1 → P0-9